

SECURITY INCIDENT REPORT

Active Directory Attack Simulation & SOC Investigation

Environment: Internal Enterprise Security Lab

Domain: CORP.LOCAL

Date: 16 May 2026

Classification: CONFIDENTIAL — Portfolio Use Only

Splunk SIEM

Sysmon

BloodHound

Impacket

Windows AD

Prepared by:

Afsar Kuttiyassan

Cybersecurity / SOC Analyst | Portfolio Project | 16 May 2026

CORP.LOCAL — Internal Lab

1. Executive Summary

This report documents a simulated multi-stage cyber attack conducted within a Windows Active Directory enterprise lab environment, designed to demonstrate real-world Security Operations Center (SOC) monitoring, detection engineering, and structured incident response workflows. All activity was performed in an isolated lab and carries no operational risk.

Attack chain simulated:

- Password spraying against Active Directory user accounts (T1110.003)
- Kerberoasting attack targeting service account SPNs (T1558.003)
- Active Directory privilege escalation path discovery via BloodHound (T1069, T1482)
- Suspicious PowerShell execution simulating post-exploitation tradecraft (T1059.001)

Security telemetry sources:

- Windows Event Logs (Security, System, PowerShell)
- Sysmon (endpoint process/network telemetry)
- Splunk Enterprise SIEM (correlation and alerting)

Incident Risk Rating: CRITICAL — Credential exposure + domain privilege escalation pathway confirmed.

2. Scope

In-Scope Systems

Asset	Role
DC01	Windows Server 2019 — Domain Controller
WIN10-CLIENT	Domain-joined Windows 10 workstation
SPLUNKSERVER	Ubuntu 22.04 — Splunk Enterprise SIEM
KALI	Attacker machine (Kali Linux 2024)

Security Stack

- Active Directory Domain Services (ADDS)
- Splunk Enterprise (SIEM + detection engineering)
- Sysmon v15 (endpoint telemetry)
- Windows Security Event Logging (Audit Policy enabled)

- BloodHound / SharpHound (AD attack path enumeration)

3. Lab Architecture

Network Components

Component	IP Address	Function
DC01	192.168.56.10	Domain Controller — Kerberos KDC, DNS, LDAP
WIN10-CLIENT	192.168.56.20	Domain-joined endpoint — victim machine
SPLUNKSERVER	192.168.56.40	Log aggregation, SIEM alerting
KALI (attacker)	192.168.56.30	Offensive tooling — Impacket, BloodHound

Logging Sources

- Windows Security Event Logs (4624, 4625, 4769, 4776)
- Sysmon Event ID 1 (Process Creation), ID 3 (Network Connections)
- Kerberos authentication events forwarded to Splunk
- PowerShell Script Block Logging (Event ID 4104)

4. Attack Timeline

Phase 1 — Password Spraying Attack

Objective

Achieve initial access by performing low-and-slow credential guessing against domain user accounts, avoiding account lockout thresholds.

Technique

SMB authentication attempts were performed against multiple Active Directory accounts using a short list of common passwords (e.g., 'Password1', 'Summer2024!'). The attack was paced below lockout thresholds.

Indicators of Compromise

- **Event ID 4625** — Multiple failed logon attempts from a single source IP (192.168.56.30)
- **Event ID 4624** — Successful authentication following repeated failures
- Multiple target usernames observed within a short time window

Splunk Detection Query

```
index=windows EventCode=4625
| bucket span=5m _time
| stats dc(user) as unique_users count by _time, src_ip
| where unique_users >= 3 AND count >= 10
| sort -count
```

Evidence — Splunk: Event ID 4625 Password Spray Detection

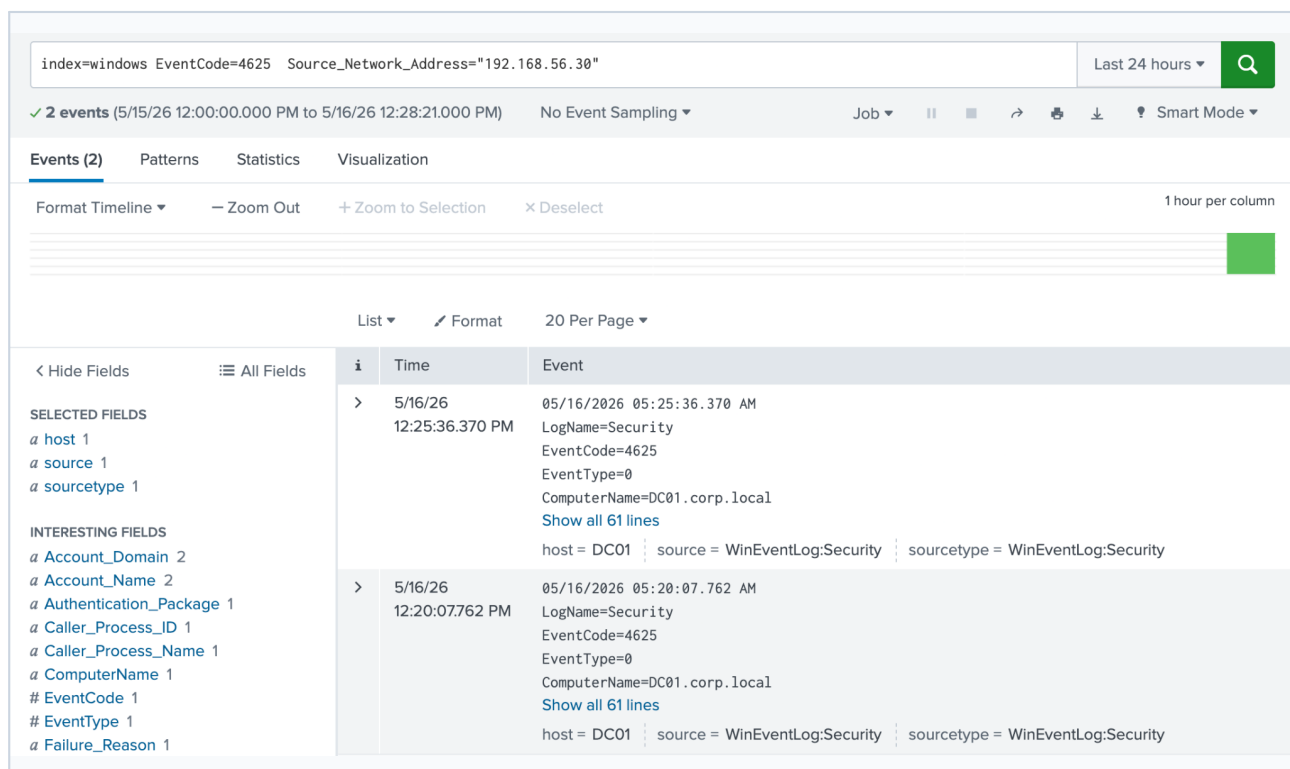


Figure 1: Splunk showing Event ID 4625 failed logon events from 192.168.56.30 (Kali attacker) — password spray activity detected against DC01.CORP.LOCAL

MITRE ATT&CK T1110.003 — Password Spraying

Phase 2 — Kerberoasting Attack

Objective

Abuse Service Principal Names (SPNs) assigned to service accounts to request Kerberos TGS tickets, extract password hashes offline, and crack weak credentials.

Technique

A test service account **SQLSVC** was created with a weak password and SPN registered. Impacket's GetUserSPNs.py was used to request TGS tickets, which were then extracted for offline cracking attempts.

Indicators of Compromise

- **Event ID 4769** — Kerberos service ticket requests (TGS-REQ) spike observed
- Ticket Encryption Type **0x17 (RC4-HMAC)** — legacy, crackable offline
- Service Account: sqlsvc / Client Address: 192.168.56.30
- Unusual volume of TGS requests from non-service workstation

Splunk Detection Query

```
index=windows EventCode=4769
Ticket_Encryption_Type=0x17 NOT Service_Name="*$"
```

```
| stats count by src_ip, Service_Name, Account_Name
| where count > 2
| sort -count
```

Evidence — Splunk: Kerberoasting Detection (Event 4769)

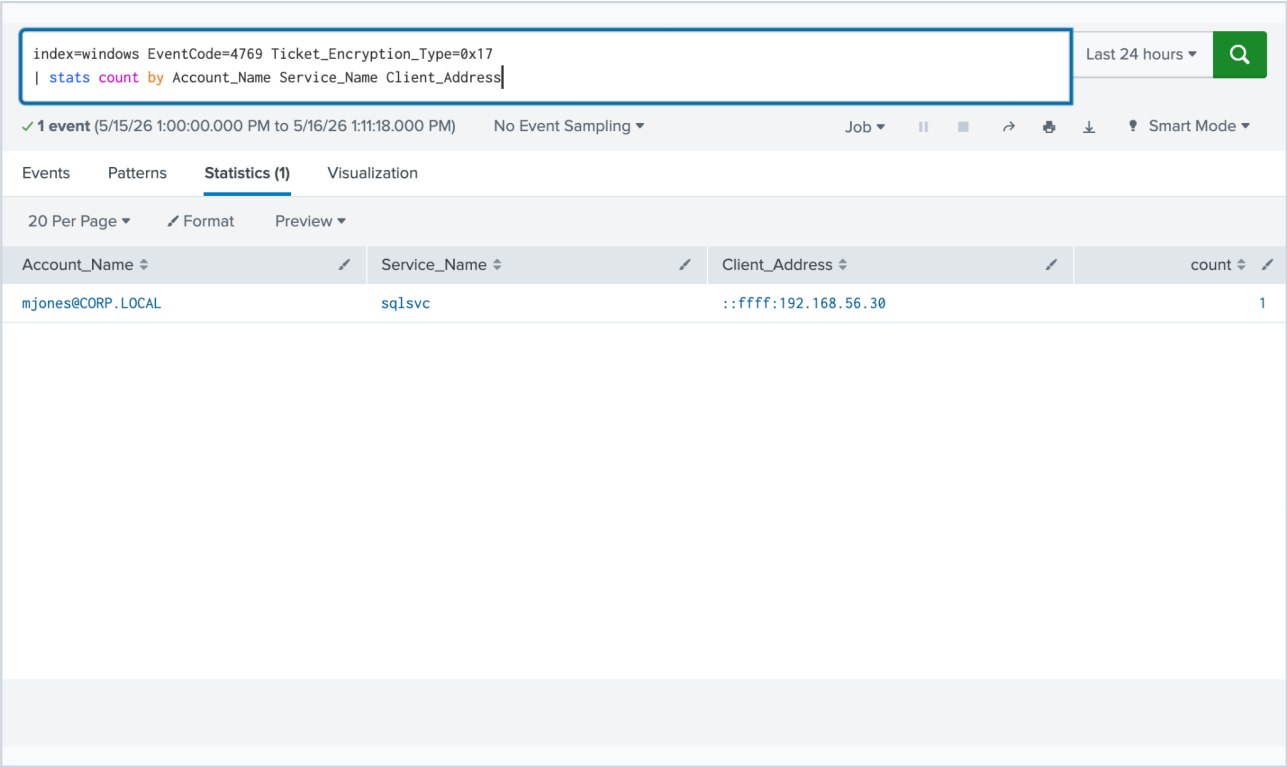


Figure 2: Splunk query result showing Event ID 4769 with RC4 (0x17) encryption type, service account sqlsvc, and attacker IP 192.168.56.30 — Kerberoasting confirmed

Evidence — BloodHound: SQLSVC Service Account Properties

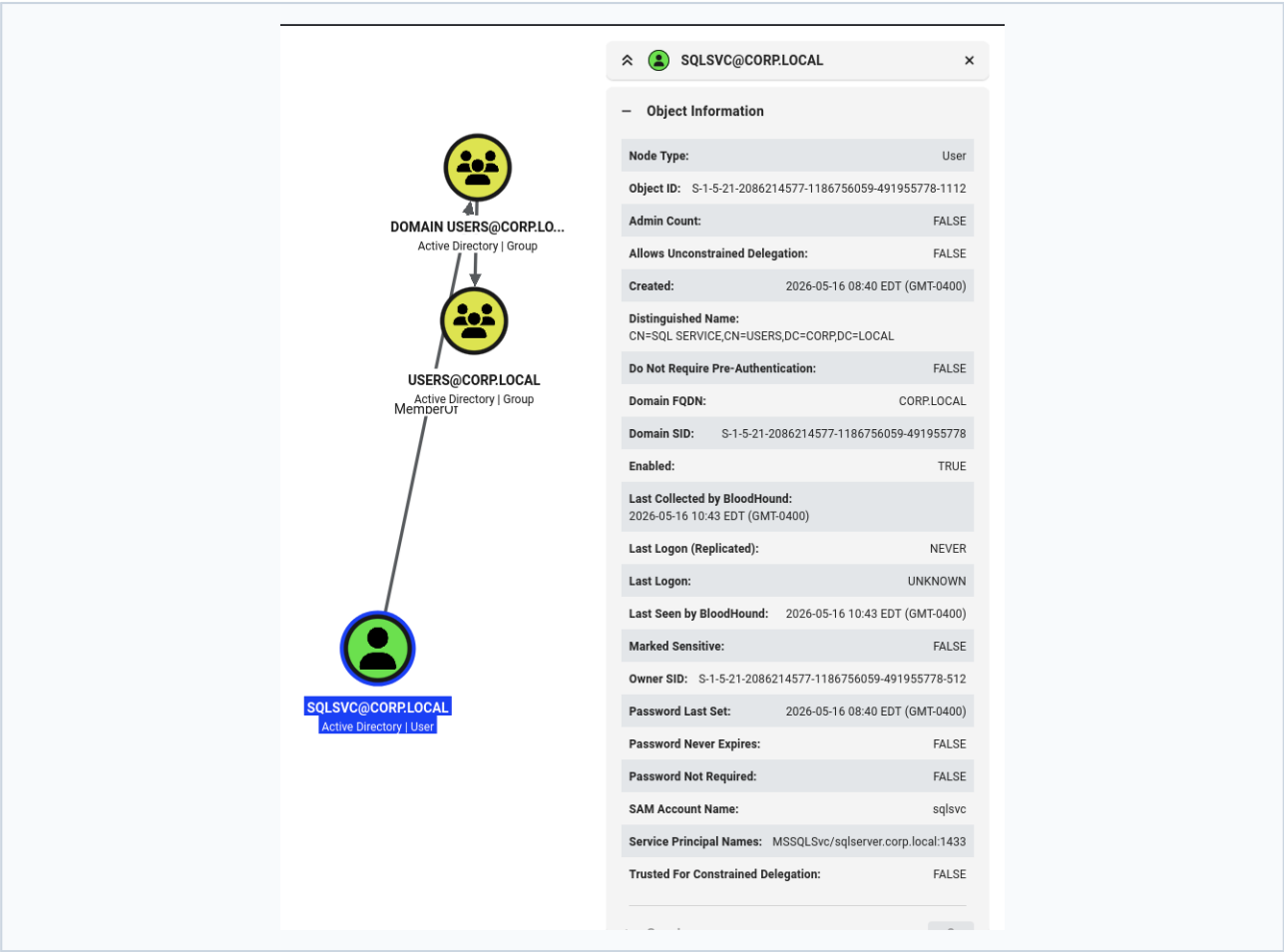


Figure 3: BloodHound object detail for SQLSVC@CORP.LOCAL showing SPN (MSSQLSvc/sqlserver.corp.local:1433), enabled status, and domain membership — confirms Kerberoastable account

MITRE ATT&CK T1558.003 — Steal or Forge Kerberos Tickets: Kerberoasting

Phase 3 — Active Directory Attack Path Analysis

Objective

Enumerate the Active Directory environment to identify privilege escalation pathways, misconfigurations, and high-value attack targets using BloodHound graph analysis.

Technique

BloodHound with the SharpHound collector ingested AD objects including users, groups, sessions, GPOs, and ACL relationships. The graph database was then queried for shortest attack paths to Domain Admin and Tier-0 assets.

Key Findings

Finding	Detail
Kerberoastable accounts	2 service accounts with SPNs and weak passwords identified
Privileged groups	Domain Admins, Enterprise Admins, Key Admins enumerated
Tier 0 assets	DC01 reachable via privilege escalation path from compromised accounts
ACL abuse path	AllExtendedRights / GenericAll rights exposed on CORP.LOCAL domain object

Evidence — BloodHound: Administrator → Domain Admins Path

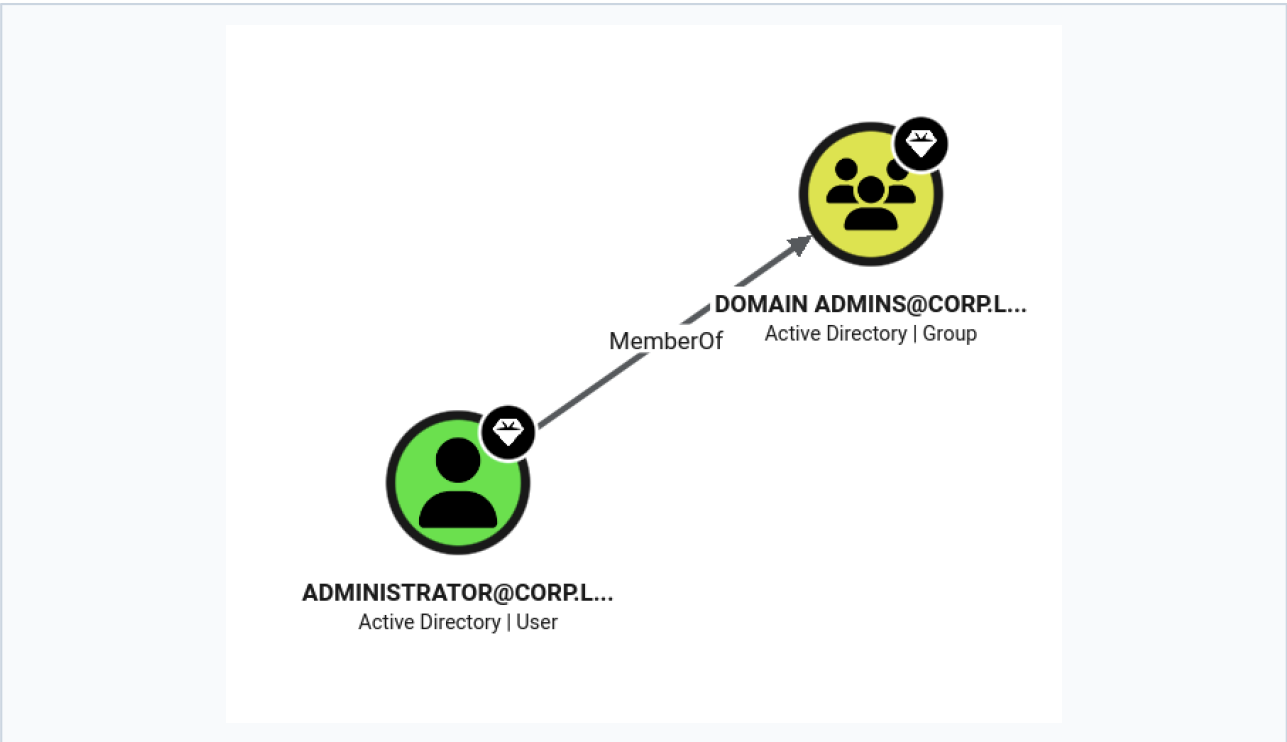


Figure 4: BloodHound showing ADMINISTRATOR@CORP.LOCAL with MemberOf relationship to DOMAIN ADMINS group — direct Tier-0 access path

Evidence — BloodHound: Privileged Group Rights on CORP.LOCAL Domain

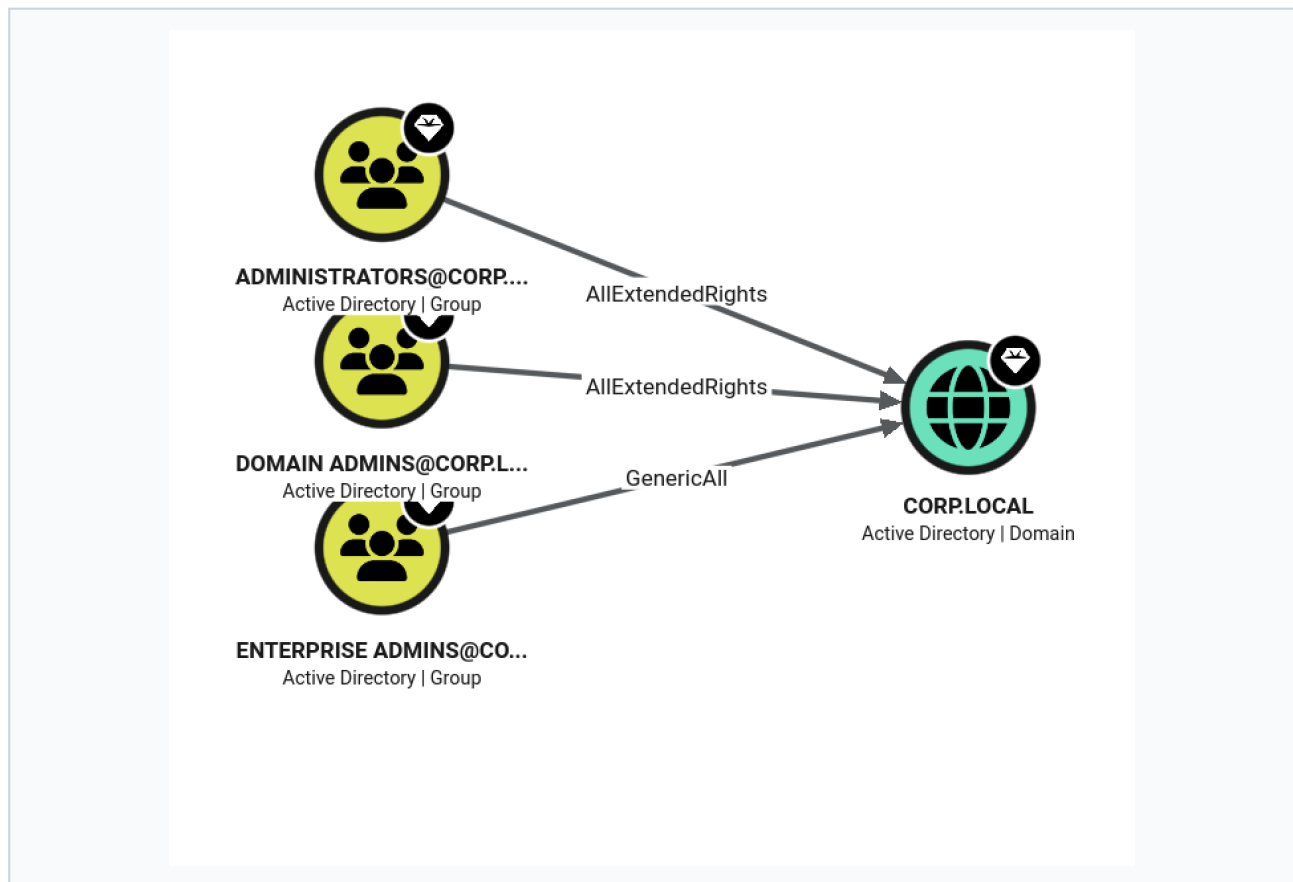


Figure 5: BloodHound showing ADMINISTRATORS, DOMAIN ADMINS, and ENTERPRISE ADMINS groups holding AllExtendedRights / GenericAll on the CORP.LOCAL domain object

Evidence — BloodHound: Privilege Escalation Path to DC01

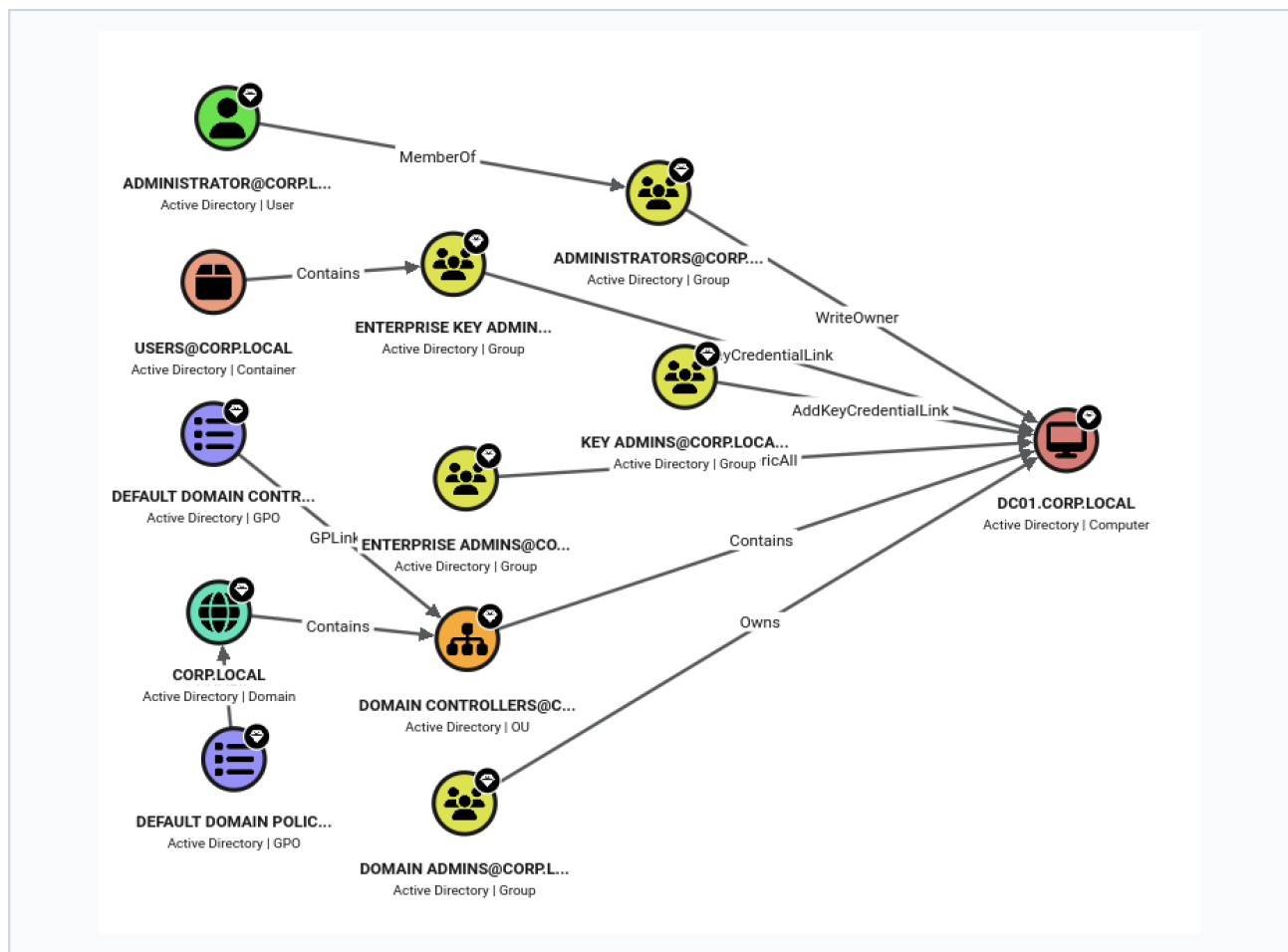


Figure 6: BloodHound full privilege escalation graph showing multiple paths (WriteOwner, AddKeyCredentialLink, GenericAll) converging on DC01.CORP.LOCAL — Tier-0 domain controller

Evidence — BloodHound: Active Directory OU Structure

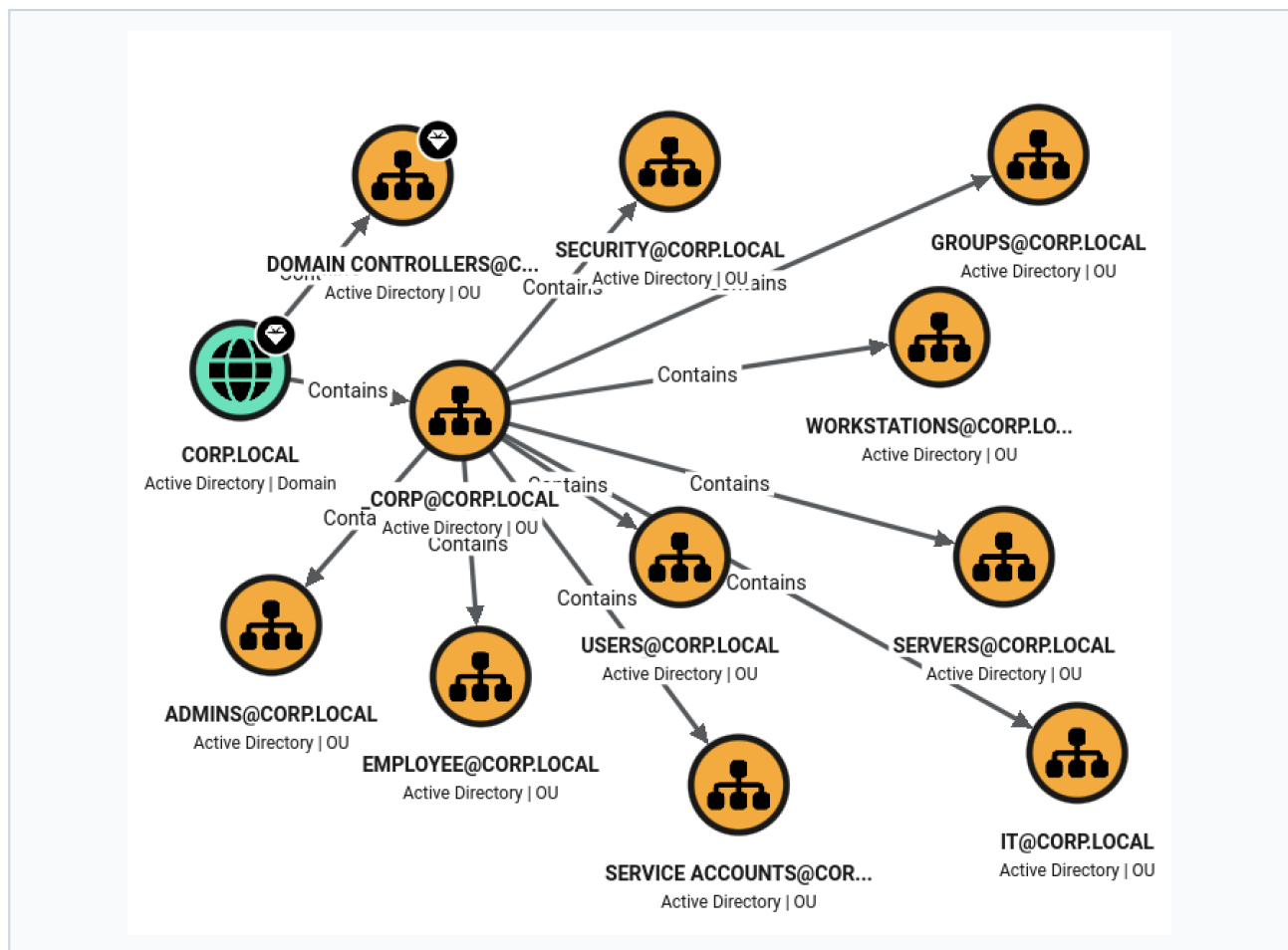


Figure 7: BloodHound OU enumeration showing complete organisational unit structure including Domain Controllers, Users, Servers, Workstations, Service Accounts, and Admin OUs

MITRE ATT&CK T1069 — Permission Group Discovery

MITRE ATT&CK T1482 — Domain Trust Discovery

Phase 4 — Suspicious PowerShell Execution

Objective

Simulate post-exploitation tradecraft using obfuscated, encoded PowerShell commands — mimicking real-world fileless malware and C2 download cradle patterns.

Technique

Encoded PowerShell commands using IEX (Invoke-Expression) and Base64 payloads were executed, triggering Sysmon process creation telemetry with suspicious parent-child process relationships.

Indicators of Compromise

- **Sysmon Event ID 1** — powershell.exe process creation with encoded command-line argument
- Presence of **-EncodedCommand** / **-Enc** flags in process arguments
- IEX keyword detected in PowerShell Script Block logs (Event ID 4104)
- Suspicious parent process: unusual application spawning PowerShell

Splunk Detection Query

```
index=sysmon EventCode=1 Image="*powershell.exe"  
| search CommandLine="*-enc*" OR CommandLine="*IEX*" OR CommandLine="*DownloadString*"   
| table _time, ParentImage, CommandLine, User
```

MITRE ATT&CK T1059.001 — Command and Scripting Interpreter: PowerShell

5. Correlation Analysis

All security log sources — authentication events, Kerberos telemetry, and Sysmon endpoint data — were ingested into Splunk and correlated to reconstruct the full attack sequence. The correlation confirmed a coherent kill chain progressing through MITRE ATT&CK stages:

Stage	Technique	Evidence Source	Risk
1. Initial Access	Password Spraying	Security Event Log 4624/4625	Medium
2. Credential Access	Kerberoasting (TGS-REQ)	Security Event Log 4769	High
3. Discovery	AD Path Enumeration	BloodHound / LDAP queries	High
4. Execution	Encoded PowerShell (IEX)	Sysmon ID 1, PS Log 4104	Critical

The unified timeline demonstrates progression consistent with: **Initial Access** → **Credential Access** → **Discovery** → **Execution**. BloodHound path analysis confirmed viable routes to domain dominance from the compromised service account, with multiple ACL abuse paths converging on DC01.

6. Impact Assessment

If this attack chain executed in a production environment with the same misconfigurations, the potential business impact would span from initial account compromise to full domain takeover:

Attack Stage	Potential Impact	Severity
Password Spraying	User account compromise, initial foothold	MEDIUM
Kerberoasting	Service account credential theft, offline cracking	HIGH
AD Privilege Discovery	Lateral movement roadmap, Tier-0 targeting	HIGH
PowerShell Execution	Fileless malware, C2 callback, data exfiltration	CRITICAL

Overall Incident Severity: CRITICAL — Full domain compromise pathway confirmed.

7. Root Cause Analysis

Root Cause	Description
Weak password hygiene	Domain users had predictable passwords susceptible to spraying

Kerberoastable SPNs	Service accounts with SPNs lacked strong passwords and used RC4 encryption
Excessive AD privileges	Service accounts had unnecessary domain group memberships
Unrestricted PowerShell	No Constrained Language Mode or AMSI bypass detection in place
Insufficient audit logging	PowerShell transcription and module logging not fully enabled

8. Mitigation Recommendations

Identity & Authentication Security

- Enforce Multi-Factor Authentication (MFA) for all privileged accounts
- Strong password policy: minimum 14 chars, complexity, 90-day rotation
- Configure account lockout: 5 failures, 30-minute lockout threshold
- Deploy Azure AD Password Protection to block common passwords

Active Directory Hardening

- Rotate all service account passwords immediately; use 25+ character random passwords
- Migrate service accounts to Group Managed Service Accounts (gMSA)
- Enforce AES256 Kerberos encryption; disable RC4 (0x17) in GPO
- Audit and reduce privileged group memberships quarterly
- Implement Tiered Administration Model (Tier 0/1/2) for AD assets

Endpoint Security Controls

- Enable PowerShell Constrained Language Mode via AppLocker/WDAC
- Enable PowerShell Script Block Logging (Event ID 4104) and module logging
- Deploy Attack Surface Reduction (ASR) rules via Microsoft Defender

SIEM Monitoring & Detection

- Alert on Event ID 4625 spikes (password spray threshold: >5/min from single IP)
- Alert on Event ID 4769 with Ticket_Encryption_Type=0x17 (Kerberoasting indicator)
- Monitor Sysmon Event ID 1 for powershell.exe with -enc or IEX arguments
- Correlate BloodHound-like LDAP queries (Event ID 1644) with endpoint telemetry

9. Detection Rules Developed

The following Splunk SPL queries were developed during this exercise and are production-ready for tuning:

Password Spraying Detection

```
index=windows EventCode=4625
| bucket span=5m _time
| stats dc(user) as unique_users count by _time, src_ip
| where unique_users >= 3 AND count >= 10
| sort -count
| table _time, src_ip, unique_users, count
```

Kerberoasting Detection

```
index=windows EventCode=4769
Ticket_Encryption_Type=0x17 NOT Service_Name="*$"
| stats count by src_ip, Service_Name, Account_Name
| where count > 2
| sort -count
```

Encoded PowerShell Abuse Detection

```
index=sysmon EventCode=1
(CommandLine="*-enc*" OR CommandLine="*IEX*"
OR CommandLine="*DownloadString*" OR CommandLine="*hidden*")
Image="*powershell.exe"
| table _time, User, ParentImage, CommandLine
```

10. Lessons Learned

- **Active Directory remains the primary target surface** — Service account misconfigurations and excessive privileges are consistently exploitable.
- **SIEM correlation dramatically improves detection confidence** — Individual events appear benign; only cross-source correlation reveals attack patterns.
- **Detection engineering requires attack knowledge** — Understanding Kerberoasting and spray thresholds directly informed effective Splunk query design.
- **Telemetry coverage gaps are a critical risk** — Without Sysmon and PowerShell logging enabled, Phase 4 activity would have generated zero alerts.
- **BloodHound visualisation changes attacker economics** — Attack path enumeration takes minutes; defenders must continuously audit AD permissions.

11. Skills Demonstrated

Offensive Security	Defensive Security	SOC Operations
Password spraying (CrackMapExec)	Splunk SIEM — search, alerts, dashboards	Incident triage & severity classification
Kerberoasting (Impacket)	Sysmon telemetry configuration	Cross-source log correlation
BloodHound AD enumeration	Windows event log analysis	Root cause analysis documentation
Encoded PowerShell simulation	Detection engineering (SPL queries)	Mitigation planning & reporting
Impacket tooling	MITRE ATT&CK mapping	Portfolio incident report writing

12. Conclusion

This lab project successfully simulated a realistic, multi-stage enterprise attack against a Windows Active Directory environment — from initial credential access through to privilege escalation reconnaissance and post-exploitation execution. All four attack phases were detected, investigated, and documented using industry-standard tooling and workflows aligned with real-world SOC analyst responsibilities.

The exercise validated the effectiveness of layered detection across Splunk SIEM, Sysmon endpoint telemetry, and Windows native event logging. Detection rules developed are directly applicable to production environments and demonstrate practical threat detection engineering capability.

This portfolio artifact reflects operational competency in SOC analysis, Active Directory security, incident response, and detection engineering — directly relevant to Security Analyst, SOC Tier II, and Security Engineer roles.

— End of Report —